《密码学基础》

第1讲：密码学概述



授课教师：徐国爱

内容 Contents



1 《密码学基础》

2 密码学概述

3 密码发展简史

4 密码学术语

1.1 课程目标-引同学进入密码殿堂



- **什么是密码？**熟知密码知识体系，建立个人密码素养
- **密码是什么？**精通关键密码算法、密码分析方法等的数学原理，熟练相关算法的软件实现
- **密码有什么用？**哪些场合需要使用密码，不同场景密码如何和业务结合，……

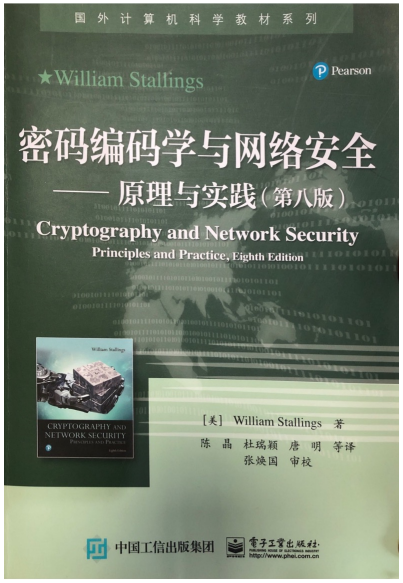
1.2 课程内容-授课32学时/实验8学时

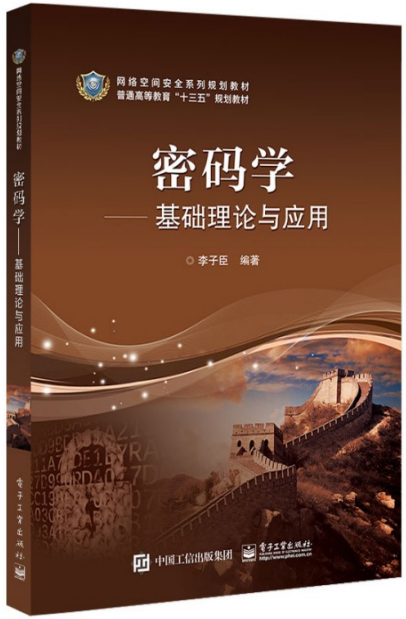


- 密码数学基础：数论、有限域
- 对称密码算法：古典密码、DES、AES、序列密码、国密等
  - AES对称加密算法实验
- 公钥密码学：RSA+Rabin+DH+ElGamal+ECC等
  - RSA公钥加密算法实验
- 密码应用技术：DS+Hash+MAC+ZK等
  - Hash哈希算法实验、ElGamal数字签名算法实验

1.3 课程资料-教材与主要参考书

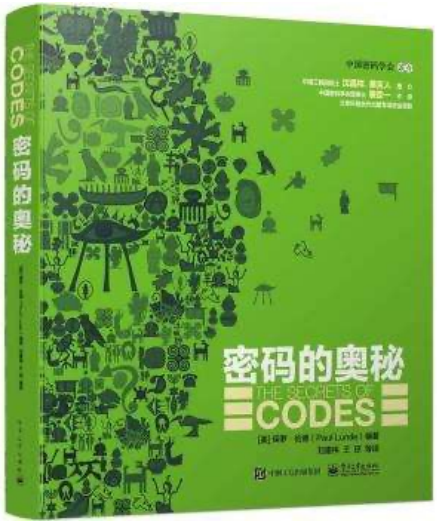
- **教材:《密码编码学与网络安全——原理与实践》，William Stallings 著，陈晶等 译，电子工业出版社，2021年4月 第八版，ISBN：978-7-121-40650-8.**
- **主要参考书：《密码学——基础理论与应用》，李子臣 编著，电子工业出版社，2019年9月 第1版，ISBN：978-7-121-36501-0.**

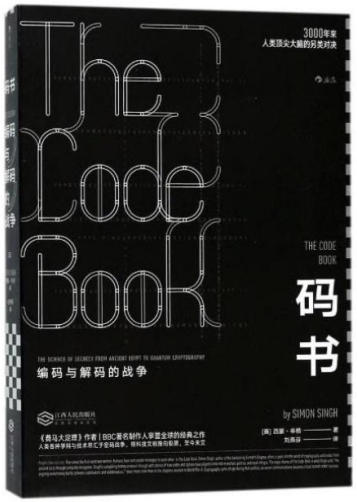




1.3 课程资料-推荐书籍

- **故事书**
  - **[美]保罗.伦德 编著，刘建伟，王琼 等译，密码的奥秘，电子工业出版社，2015**
  - **[英]西蒙.辛格 著，刘燕芬 译，码书，江西人民出版社，2018**
  - **王善平，张奠宙，二战时期密码决战中的数学故事，高等教育出版社，2008**

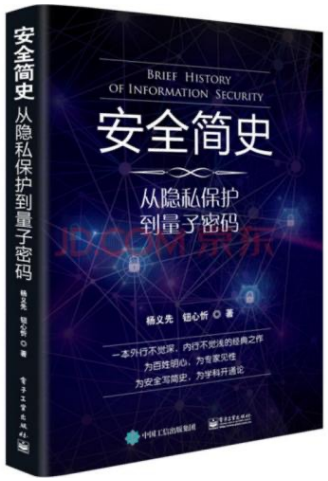


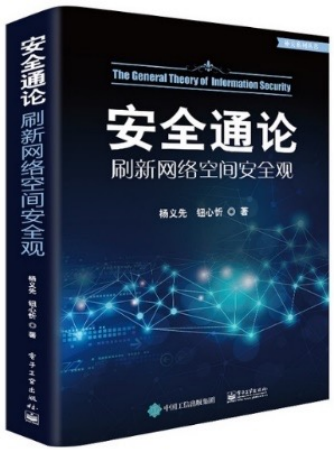




1.3 课程资料-推荐书籍

- **介绍性**
  - **杨义先，钮心忻 著，安全简史（从隐私保护到量子密码），电子工业出版社，2017**
  - **杨义先，钮心忻 著，安全通论（刷新网络空间安全观），电子工业出版社，2018**
  - **[日]结城浩 著，周自恒 译，图解密码技术，人民邮电出版社，2014**

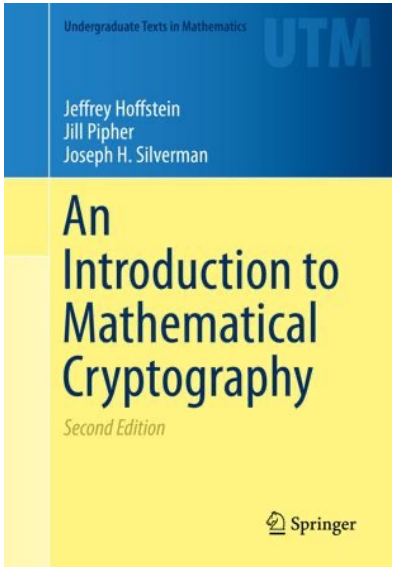


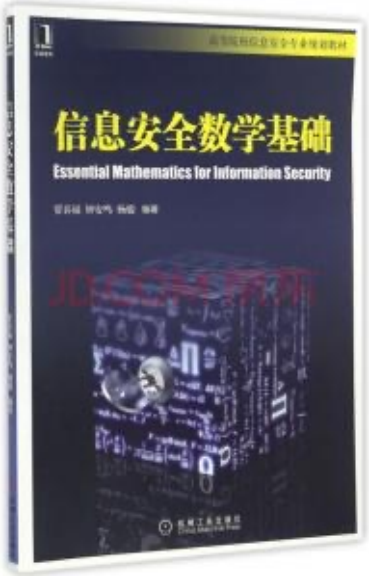




1.3 课程资料-推荐书籍

- **密码学相关数学基础**
  - **Jeffrey Hoffstein, Jill Pipher, Joseph H. Silverman. Introduction to Mathematical Cryptography, 2th Edition. Springer, 2014**
  - **贾春福，钟安鸣，杨骏 编著，信息安全数学基础，机械工业出版社，2017**





1.4 其他情况



- **考核：20%平时 + 30%实验 + 50%期末考试**
  - 课后作业（下一周提交）+ 随堂作业（1-2次）+课堂问答（不定次）+选择题征集（不定次）+考勤
  - 课后作业正确1题计1次、抄袭计负次、word文档形式提交，随堂做作业计10次，选择题每题计1次，课堂问答实际发生计次，缺勤一次计负1次
  - 总在勤次数合格作为期末考试前置条件
- **联系方式：**
  - **主讲教师：徐国爱，xga@hit.edu.cn**
  - **教学助理：陈广鸣**
  - **微信通知群：**

内容 Contents



1 《密码学基础》

2 密码学概述

3 密码发展简史

4 密码学术语

2.1 什么是“密码”



- 登录邮箱或淘宝时需要用户名和密码、刷银行卡消费或取款时需要输入密码等等——“口令”（password、passcode、pin）
- “神秘的编码”，譬如DNA 称作“遗传密码”等——也不是“密码”
- 银行使用的U盾，网络应用中的数字证书、VPN、https等等——“密码”的应用
- “中华人民共和国保守秘密法” 中的“秘密”、“机密”和“绝密”——和“密码”没有必然关系
- 破解、越狱、ROOT、软件“加密” 等——基本和“密码”无关
- 密码术一词最早起源于希腊语，其包含“隐藏”和“书写”两方面内容。“密码”是一类涉及信息的机密性、完整性、认证性、不可否认性等处理的技术方法，进而：密码学（cryptography）

2.2 网络空间安全及相关说法



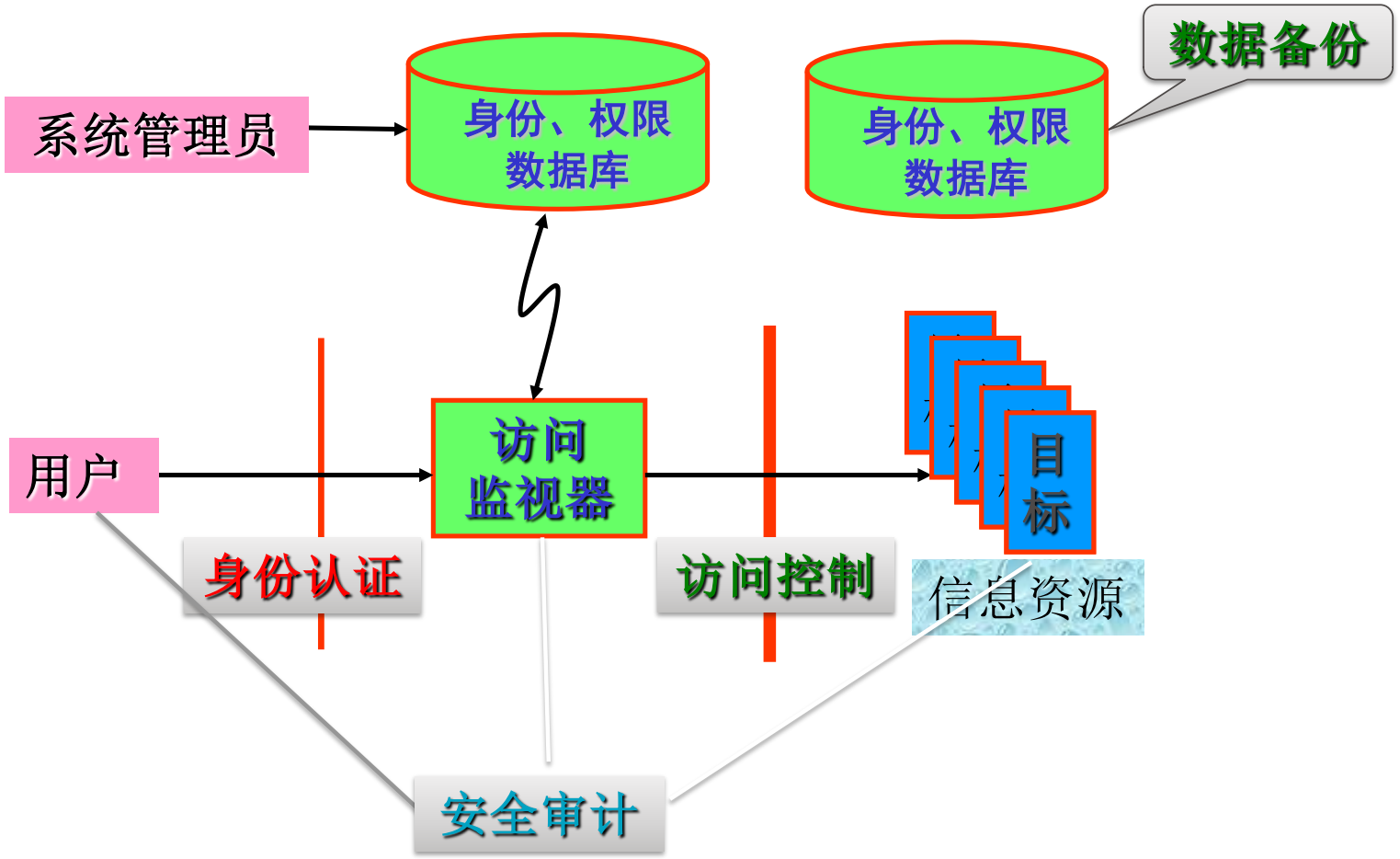
- 信息安全：指信息网络的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、泄露、更改、假冒、否认等，系统连续可靠正常地运行，信息服务不中断。
- 信息安全可分为狭义安全与广义安全两个层次，狭义的安全是建立在以 密码技术 基础的计算机安全领域，辅以通信技术、计算机技术与网络技术等方面的内容；广义的信息安全是一门综合性学科，安全不在是单纯的技术问题，而是将管理、技术、法律等问题相结合的产物。
- 信息安全、网络安全、网络空间安全、通信安全、信息网络安全、网络信息安全等都是特定环境的说法，内涵、外延只能依据语境进行判断
- 网络空间安全 ≈ 密码学 + 缺陷学

2.3 信息安全基本属性



- 机密性：信息不泄漏给非授权的用户、实体或者过程
  - 密码是改善机密性的有力手段，访问控制是基本技术
- 完整性：数据未经授权不能进行改变，即信息在存储或传输过程中保持不被修改、不被破坏和丢失等
  - 密码技术常用于改善完整性
- 可用性：可被授权实体访问并按需求使用的特性，即当需要时应能存取所需的信息
- 真实性：内容的真实性
- 可核查性：对信息的传播及内容具有控制能力
- 可靠性：系统可靠性

信息系统安全模型



两种访问控制模型



- 自主访问控制模型（DAC Model，Discretionary Access Control Model）
  - 允许合法用户以用户或用户组的身份访问策略规定的客体，同时阻止非授权用户访问客体，允许某些用户自主地把自己所拥有的客体的访问权限授予其它用户（又称为任意访问控制）
  - **配置的粒度小**
  - **配置的工作量大，效率低**

- 强制访问控制模型（MAC Model：Mandatory Access Control Model）
  - 和DAC模型不同的是，MAC是一种多级访问控制策略，数据所有者无权决定文件的访问权限，权限由操作系统决定，可能覆盖所有者的设置
  - **配置的粒度大**
  - **缺乏灵活性**

2.4 密码应用-网络安全防护核心



- 领域：军、政、民
- 开放环境：互联网、供应链制约，互联网加密流量已超80%
- 特殊业务：电子货币、电子投票、区块链应用等
- 密码已经不再仅仅属于专家和研究人员，而是我们每一个生活在现代社会的人都要掌握或了解的一门基本技术。

内容 Contents



1 《密码学基础》

2 密码学概述

3 密码发展简史

4 密码学术语

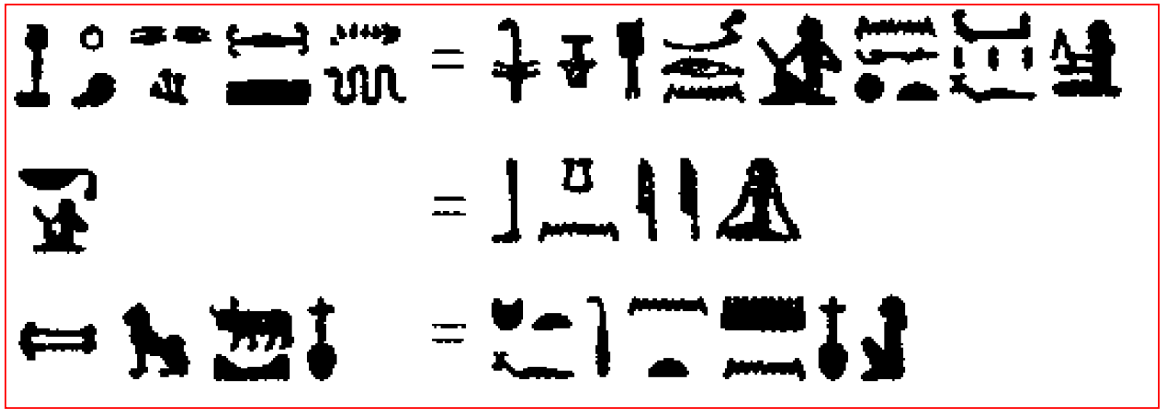
3.1 古典密码：1949年前



- 密码学还不是科学，而是一门技术性很强的艺术
- 出现一些密码算法和设备
- 主要特点：数据安全基于算法保密

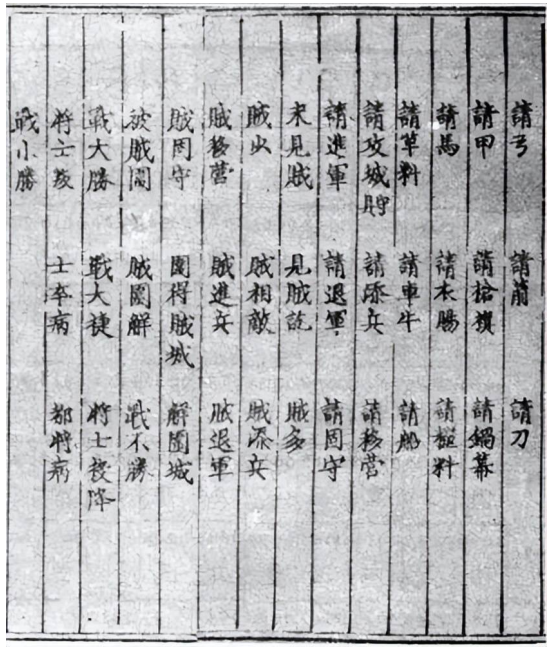
3.1 古典密码例子-古埃及变形象形文字铭文

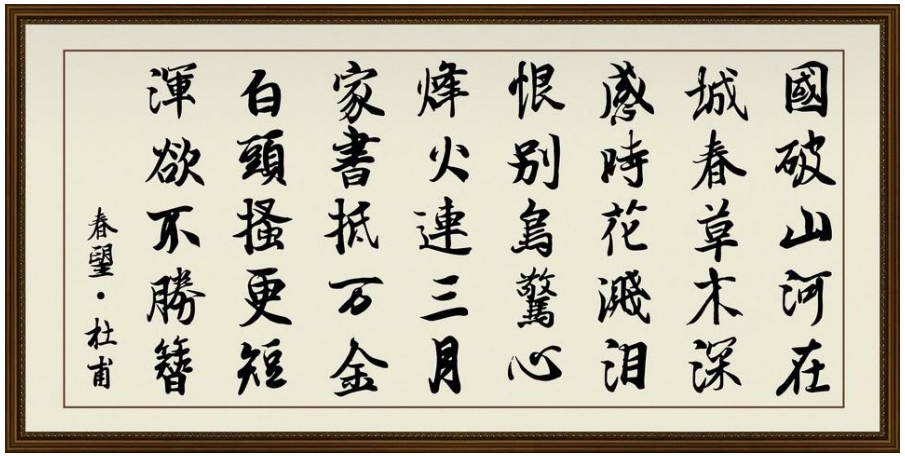
- 大约4000年前，在古埃及尼罗河畔，一位擅长书写者在贵族的基碑上书写铭文时有意用加以变形的象形文字而不是普通的象形文字来写铭文
  - 揭开有文字记载的密码史
  - 如图颇具神秘感的碑文，已具备了密码的基本特征：**把一种符号(明文)用另一种符号(密文)代替**



3.1 古典密码例子-宋朝的字验

- 字验是宋朝的军事密码
  - 将一首诗中一个字来代替一个军事信息或者军事活动，如“金”字表示“贼多”
  - 前方指挥官在派遣情报人员向后方递送情报的时候，就可以在“金”字上做特殊标记，后方收到后，根据密码本核对，便知道了前方“敌人特别多”的信息





40字律诗《春望》

https://www.sohu.com/a/549104390_120925264

3.1 古典密码例子-古斯巴达人的密码棒

- 公元前5世纪，古斯巴达人使用了一种叫做“密码棒”(Scytale)的器械，这是人类历史上最早使用的密码器械
  - Scytale是一根用草纸条、皮条或羊皮纸条紧紧缠绕的木棍。密信自上而下写在羊皮纸条上。然后把羊皮纸条解开送出。把羊皮纸条重新缠在一根直径和原木棍相同的木棍上，这样字就一圈圈跳出来。

密文： K T M I O I L M D L O N K R I I R G N O H G W T

如何解密?



竖排横读

明文： K I L L K I N G T O M O R R O W M I D N I G H T

3.2 近代密码：1949年-1975年



- 1949年 香农“保密系统的通信理论”
  - 从理论高度探讨了密码保密问题，奠定了密码学的基础

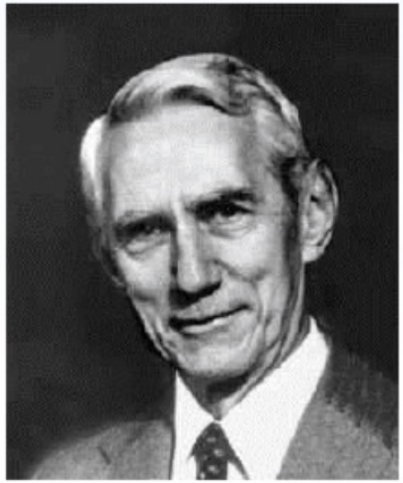
- 1967年，Kahn收集整理了两次世界大战的大量史料，出版了《破译者》（The Code Breakers）
  - 对密码学的历史做了相当完整的记述，为密码技术的公开化、大众化拉开了序幕。此后，关于密码学文献源源不断地涌现出来。

- 1971年-73年 IBM Watson实验室关于Horst Feistel等的报告
  - A Cryptographic Device for Data Communication, 1971
  - An Experimental Application of Cryptography to a remotely Accessed Data System, 1972
  - Cryptography and Computer Privacy, 1973

- 主要特点：数据的安全基于密钥而不是算法的保密

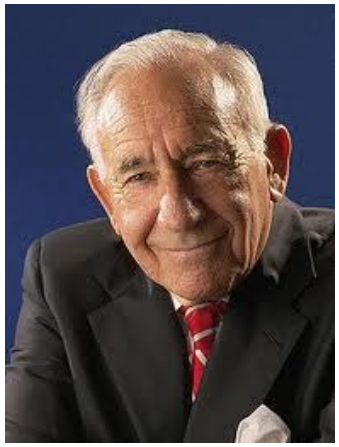
“信息论之父”

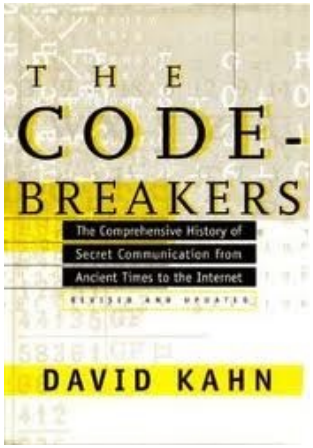
“现代密码学的先驱”



香农



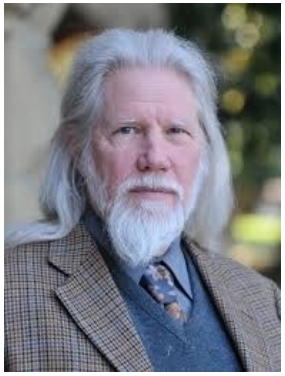




3.3 现代密码：1976年至今



- 1976年11月，Diffiie和Hellman发表“New directions in cryptography”
  - 提出了适应网络保密通信的公钥密码思想
  - 开创了公钥密码的新纪元



Whitfield Diffie
惠特菲尔德·迪菲



Martin Hellman
马丁·赫尔曼



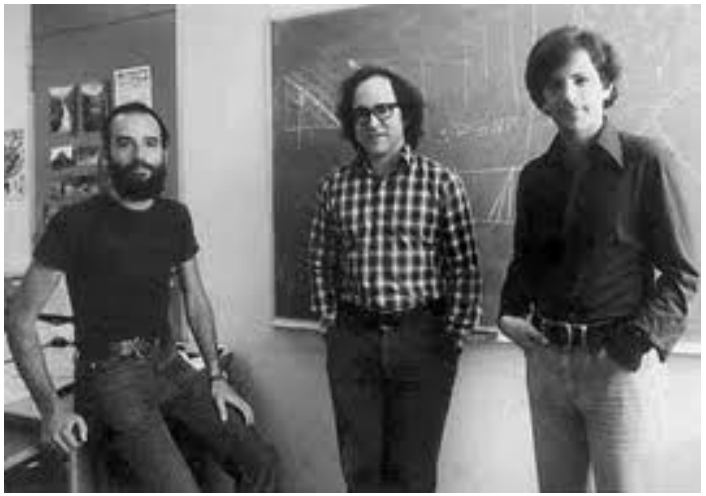
2002

3.3 现代密码：1976年至今



- 1977年 Rivest, Shamir & Adleman提出RSA公钥加密算法

- 20世纪90年代逐步出现椭圆曲线等其它公钥算法



Adi Shamir Ron Rivest Len Adleman
阿迪·沙米尔 罗纳德·李维斯特 伦纳德·阿德曼



2015

3.3 现代密码：1976年至今-对称密码算法进展



- 1977年，美国国家标准局公布联邦信息处理标准：数据加密标准（DES），这是国际上第一个被公布出来的标准算法，形成了密码学行业的初期规范
- 80年代出现“过渡性”的“post DES”算法，如IDEA,RCx,CAST等
- 90年代对称密钥密码进一步成熟 Rijndael, RC6, MARS, Twofish, Serpent等出现
- 2001年Rijndael/AES成为DES的替代者。

3.4 国产密码发展历程



- 1999年，国务院开始施行《商用密码管理条例》，以法律条文的方式确定了党和国家关于商用密码的要求与期望，标志着我国商用密码的法制化
- 2003年9月，中办国办联合印发《关于加强信息安全保障工作的意见》，第一次明确了密码在信息安全保障工作中的基础性地位和关键作用
- 2004年8月28日第十届全国人民代表大会常务委员会第十一次会议通过《中华人民共和国电子签名法》、2005年元旦生效，确立电子签名的法律效率，后2016年修订
- 2019年10月，十三届全国人大常委会第十四次会议表决通过密码法
- 20多年间，密码管理局陆续制定了一系列国家商用密码标准，这些标准已经应用到社会生产生活的各个方面，发挥着重要的基础支撑作用

我国制定密码法全面提升密码工作法治化水平

十三届全国人大常委会第十四次会议10月26日表决通过密码法，将自2020年1月1日起施行

密码法旨在

规范密码应用和管理，促进密码事业发展，保障网络与信息安全，提升密码管理科学化、规范化、法治化水平，是我国密码领域的综合性、基础性法律



密码法规定，国家对密码实行分类管理

- 密码分为核心密码、普通密码和商用密码
- 核心密码、普通密码用于保护国家秘密信息，属于国家秘密
- 商用密码用于保护不属于国家秘密的信息
- 公民、法人和其他组织可以依法使用商用密码保护网络与信息安全



密码法规定

- 国家加强核心密码、普通密码的科学规划、管理和使用，加强制度建设，完善管理措施，增强密码安全保障能力
- 国家鼓励商用密码技术的研究开发、学术交流、成果转化和推广应用，健全统一、开放、竞争、有序的商用密码市场体系，鼓励和促进商用密码产业发展

新华社记者 胥晓璇 编制

内容 Contents



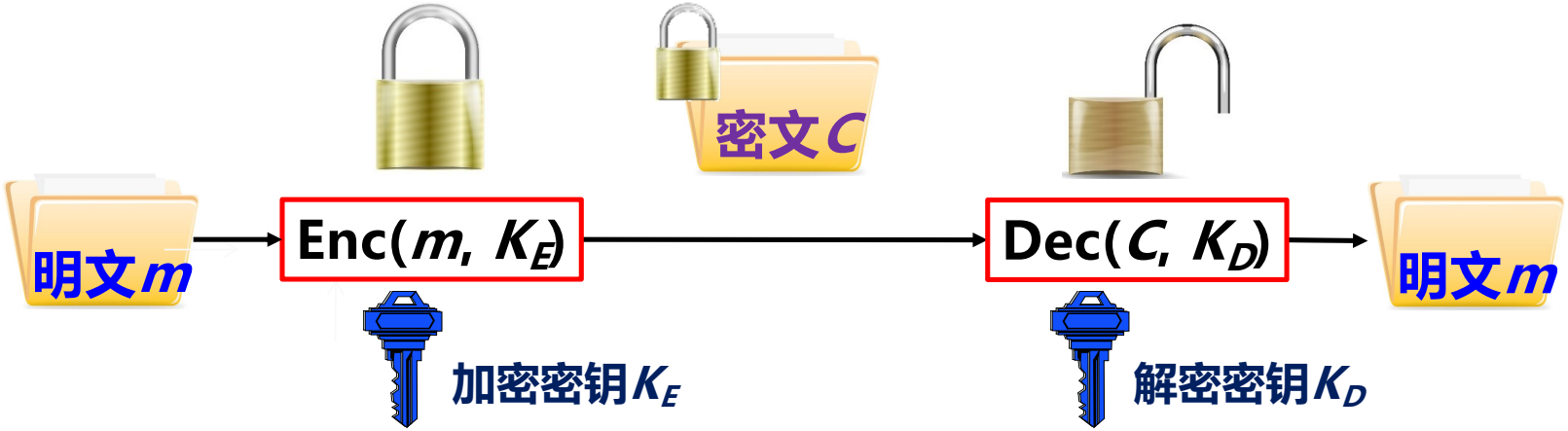
1 《密码学基础》

2 密码学概述

3 密码发展简史

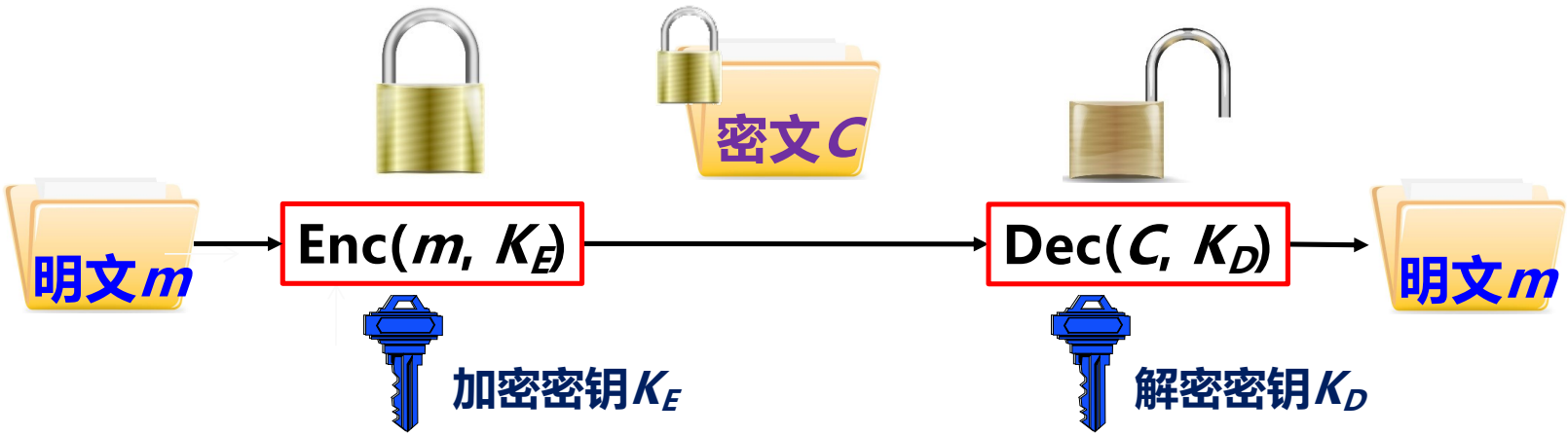
4 密码学术语

4.1 密码系统（体制）



- 明文m：发送方即将要发送的消息
- 密文C：明文经过加密后的消息
- 加密Enc：由明文变换为密文的过程，基于特定的规则进行（加密算法），**数学变换族**
- 解密Dec：由密文恢复出原明文的过程，基于特定的规则进行（解密算法）
- 加密密钥K_E：加密时使用的密钥，加密变换索引
- 解密密钥K_D：解密时使用的密钥，解密变换索引

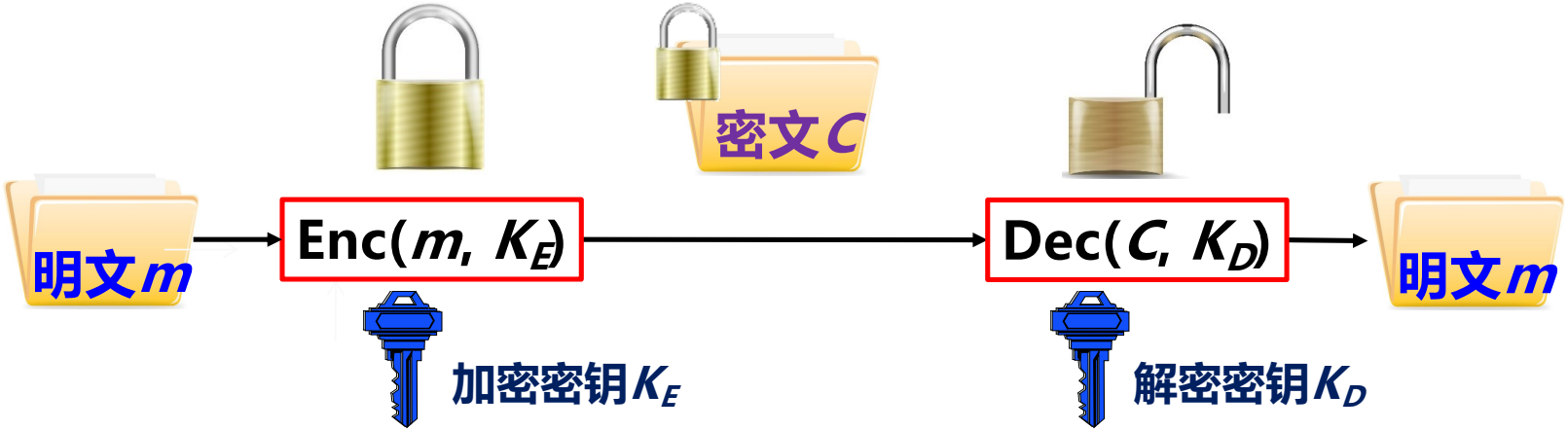
4.2 对称密码体制



对称加密：$K_E = K_D$，均需保密

- 对称加密(Symmetric encryption)：加密和解密由同一个密钥来控制，也叫“单钥加密”。
  - 采用单钥体制的系统的保密性主要取决于密钥的保密性，与算 法的保密性无关, 即由密文和加解密算法无法得到明文。
  - 对明文消息的加密有两种方式：
    - 流密码：对明文消息按字符(如二元数字)逐位地进行加密。
    - 分组密码：将明文消息分组(含有多个字符)，逐组地进行加密。

4.3 非对称密码体制



非对称加密：$K_E \neq K_D, K_E$可以公开，K_D需保密

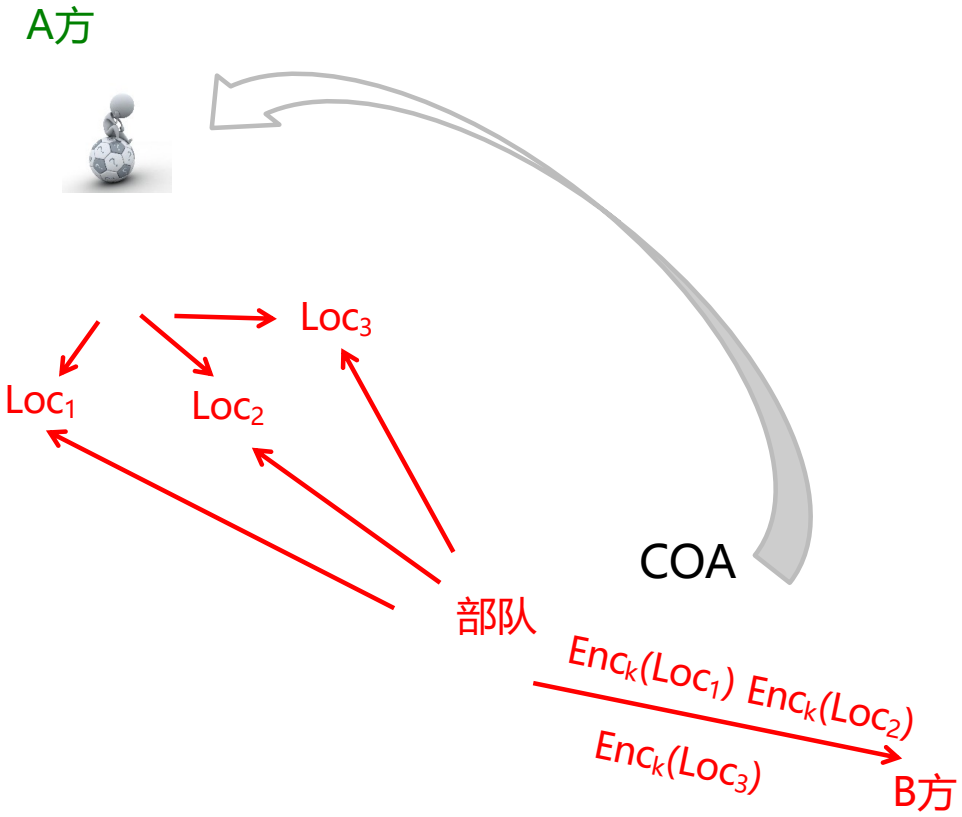
- 非对称加密(Asymmetric encryption)：用作加密的密钥不同于用作解密的密钥，而且解密密钥不能根据加密密钥计算出来，也叫“公钥加密”。
  - 可以实现多个用户加密的消息只能由一个用户解读，可用于公共网络中实现保密通信
  - 类比：撞锁、意见箱等

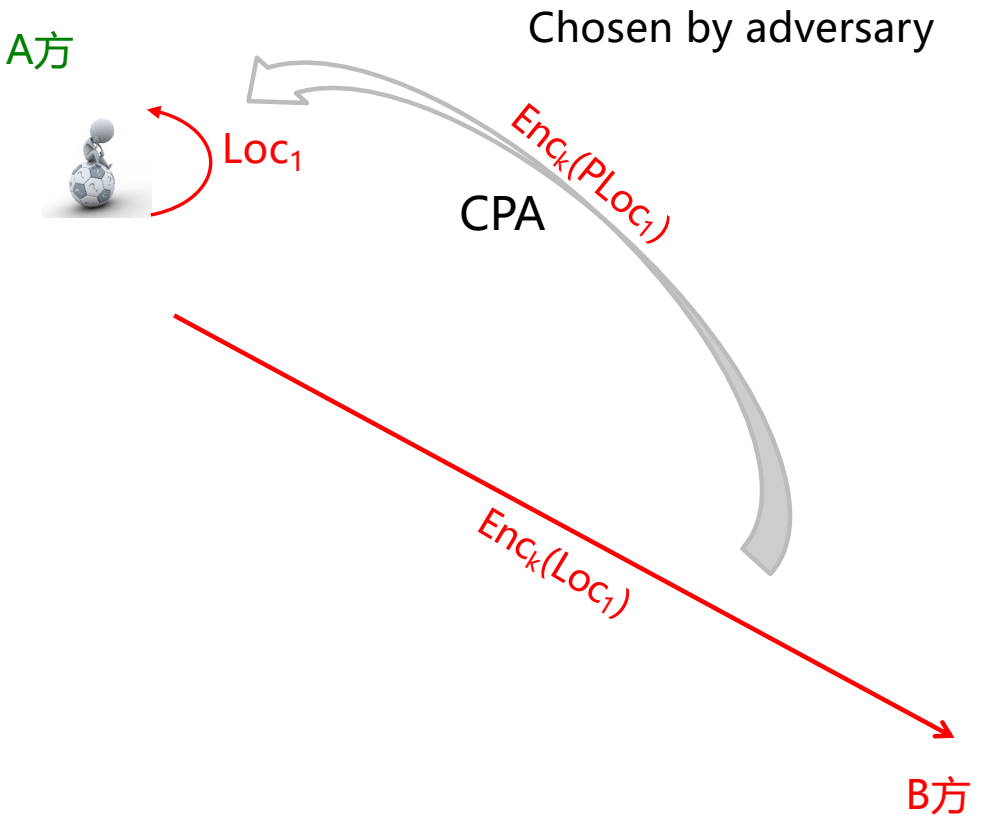
4.4 密码攻击、密码分析



- 攻击类型的划分由攻击者可获取的信息量决定
  - ➢ 唯密文攻击时，敌手知道的信息量最少，因此最易抵抗

攻击类型	攻击者掌握的内容
唯密文攻击(COA)	● 加密算法 ● 截获的部分密文
已知明文攻击(KPA)	● 加密算法 ● 截获的部分密文 ● 一个或多个明文密文对
选择明文攻击(CPA)	● 加密算法 ● 截获的部分密文 ● 自己选择的明文消息，及由密钥产生的相应密文
选择密文攻击(COA)	● 加密算法 ● 截获的部分密文 ● 自己选择的密文消息，及相应的被解密的明文


A方
Loc3
Loc1
Loc2
COA
部队
Enck(Loc1) Enck(Loc2)
Enck(Loc3)
B方


A方
Chosen by adversary
Loc1
Enck(PLoc1)
CPA
Enck(Loc1)
B方

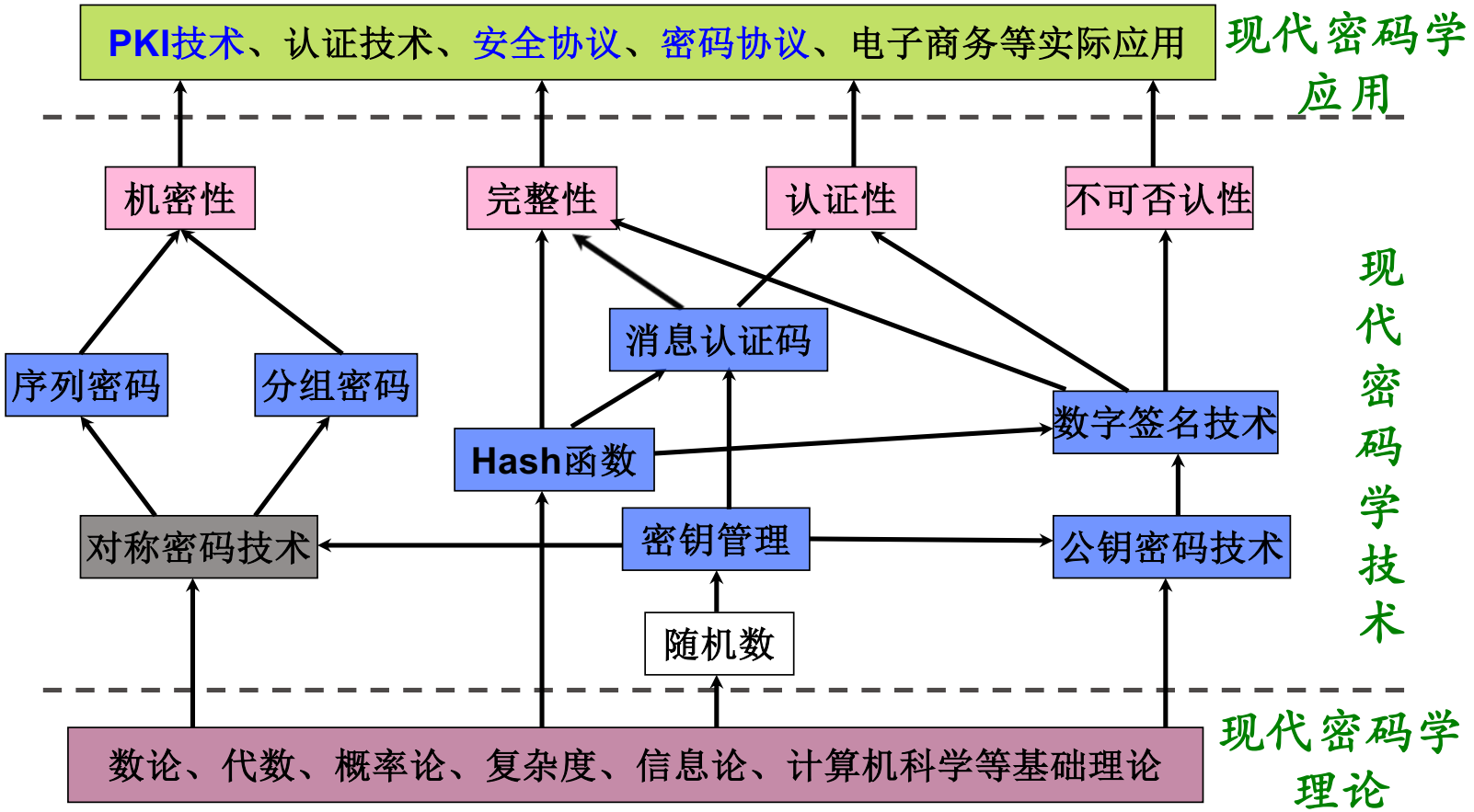
4.5 密码安全



- 无条件安全：
  - 一个加密算法是无条件安全的，如果算法产生的密文不能给出惟一决定相应明文的足够信息。此时无论敌手截获多少密文、花费多少时间，都不能解密密文
  - 香农指出，仅当密钥至少和明文一样长时，才能达到无条件安全。也就是说除了**一次一密**方案外，再无其他的加密方案是无条件安全的

- 计算安全
  - 比无条件安全弱的一个概念是计算上安全的。加密算法只要满足以下两条准则之一就称为是计算上安全的：（1）破译密文的代价超过被加密信息的价值；（2）破译密文所花的时间超过信息的有用期

4.6 密码学知识体系——现代密码学基本内容



小结



① 密码学发展的历史

1. 古典、近代、现代的不同特点
2. 里程碑与图灵奖

② 国产密码发展历程

③ 密码学相关术语和概念

1. 公钥密码学 vs 私钥密码学
2. 非对称加密 vs 对称加密
3. 公钥加密 vs 私钥解密
4. 4种攻击（COA，KPA，CPA，CCA）

思考



- 1、为什么非对称密码成为现代密码的核心？
- **2、结合对密码分析的理解，讨论密码算法安全性评价。**
- 3、如何理解密码与网络空间安全的关系的关系？



谢 谢